

Threat Analysis Report

รายงานวิเคราะห์ภัยคุกคามจากการ
นำ MeshAgent และ RMM ไปใช้
ในทางมิชอบเพื่อควบคุมระบบ

31/05/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
Threat Overview	4
การวิเคราะห์เชิงเทคนิค.....	5
Tactics, Techniques, and Procedures (MITRE ATT&CK)	13
Indicator of Compromise (IOCs).....	14
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	15
อ้างอิง (References).....	19



บทสรุปสำหรับผู้บริหาร

จากการวิเคราะห์ข้อมูลภัยคุกคาม พบแนวโน้มการนำเครื่องมือ Remote Monitoring and Management (RMM) โดยเฉพาะ MeshAgent ไปใช้ในทางมิชอบ เพื่อควบคุมเครื่องคอมพิวเตอร์ คงสิทธิ์การเข้าถึงระบบ และสนับสนุนการโจมตีในขั้นตอนถัดไป

MeshAgent เป็นเครื่องมือสำหรับบริหารจัดการเครื่องปลายทางจากระยะไกล ไม่ใช่มัลแวร์ โดยตัวเอง อย่างไรก็ตาม หากถูกติดตั้งหรือใช้งานโดยผู้ไม่หวังดี อาจทำให้ผู้โจมตีสามารถส่งรันท้าสั่ง ถ่ายโอนไฟล์ สืบค้นเครือข่าย และกลับเข้าควบคุมระบบได้อย่างต่อเนื่อง

จากข้อมูลที่ตรวจพบ มีร่องรอยที่เกี่ยวข้องกับการดาวน์โหลด MeshAgent และไฟล์ Configuration จากโครงสร้างพื้นฐานภายนอก การพบ Webshell บนระบบ Tomcat การใช้งาน เครื่องมือสำรวจเครือข่าย เช่น fscan และ nmap รวมถึงเครื่องมือที่เกี่ยวข้องกับ SSH automation เช่น sshpass และ paramiko

ภัยคุกคามลักษณะนี้มีความเสี่ยงสูง เนื่องจาก RMM เป็นเครื่องมือที่ถูกต้องตามกฎหมาย และอาจมีพฤติกรรมคล้ายการดูแลระบบตามปกติ ทำให้ตรวจจับได้ยาก หากองค์กรไม่มีการควบคุม รายการเครื่องมือที่อนุญาตและไม่มีการเฝ้าระวังการเชื่อมต่อ Remote Access อย่างเหมาะสม



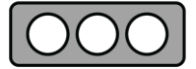
Threat Overview

Remote Monitoring and Management (RMM) เป็นเครื่องมือที่องค์กรใช้สำหรับบริหารจัดการเครื่องคอมพิวเตอร์และเซิร์ฟเวอร์จากระยะไกล เช่น การตรวจสอบสถานะระบบ การสนับสนุนผู้ใช้งาน การถ่ายโอนไฟล์ และการสั่งรันคำสั่งบนเครื่องปลายทาง อย่างไรก็ตาม เครื่องมือประเภทนี้สามารถถูกนำไปใช้ในทางมิชอบได้ หากผู้ไม่หวังดีสามารถติดตั้งหรือควบคุม Agent บนระบบของเหยื่อ

MeshAgent เป็น Agent ของ MeshCentral ซึ่งใช้สำหรับเชื่อมต่อเครื่องปลายทางกลับไปยังเซิร์ฟเวอร์ควบคุม เพื่อให้ผู้ดูแลระบบสามารถบริหารจัดการเครื่องจากระยะไกลได้ ในบริบทของภัยคุกคาม ผู้โจมตีอาจนำ MeshAgent ไปติดตั้งบนเครื่องที่ถูกบุกรุก และกำหนดค่าให้เชื่อมต่อกลับไปยังเซิร์ฟเวอร์ที่ผู้โจมตีควบคุม เพื่อใช้เป็นช่องทางควบคุมระบบ คงสิทธิ์การเข้าถึง หรือสั่งรันคำสั่งเพิ่มเติม

ภัยคุกคามจาก RMM มีความน่ากังวล เนื่องจากเครื่องมือเหล่านี้เป็นซอฟต์แวร์ที่ถูกต้องตามกฎหมาย และมักใช้การเชื่อมต่อผ่าน HTTPS ซึ่งอาจถูกกลืนกับการใช้งานปกติขององค์กร หากไม่มีการจัดทำรายการเครื่องมือที่ได้รับอนุญาต หรือไม่มีการตรวจสอบปลายทางที่ Agent เชื่อมต่อ อาจทำให้ผู้โจมตีสามารถแฝงตัวอยู่ในระบบและดำเนินกิจกรรมต่อเนื่องได้โดยตรวจจับได้ยาก

ในกรณีที่ตรวจพบ มีร่องรอยที่สอดคล้องกับการนำ MeshAgent/RMM ไปใช้ในทางมิชอบร่วมกับพฤติกรรมอื่น เช่น การใช้ Webshell บนระบบ Web Application การดาวน์โหลดไฟล์จากโครงสร้างพื้นฐานภายนอก การสำรวจเครือข่าย และการใช้เครื่องมือสำหรับเชื่อมต่อผ่าน SSH ซึ่งสะท้อนถึงความเป็นไปได้ของการควบคุมระบบและการขยายผลการโจมตีภายในเครือข่าย

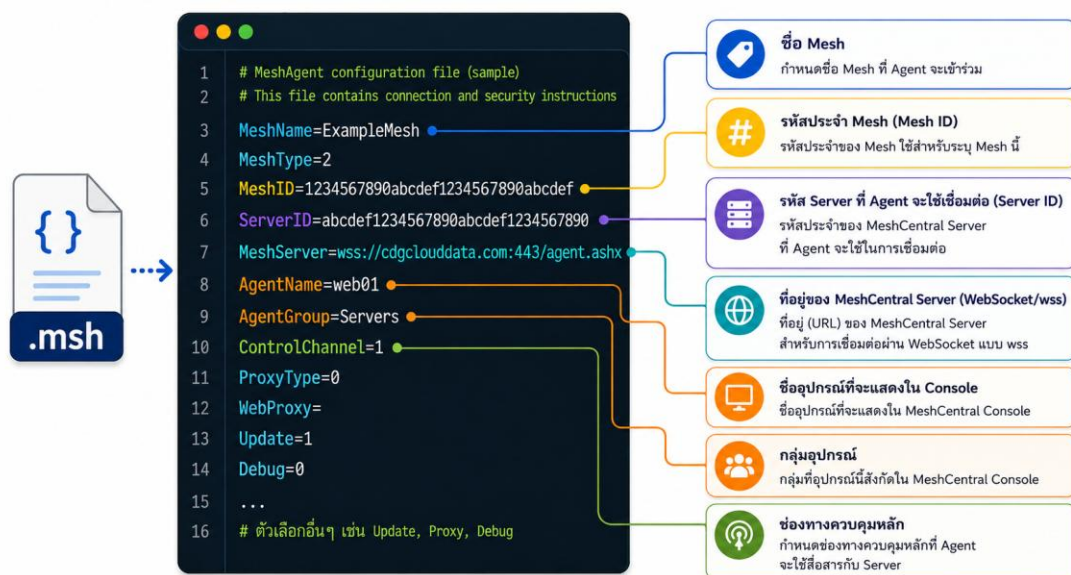


การวิเคราะห์เชิงเทคนิค

จากข้อมูลที่ตรวจพบ กรณีนี้มีลักษณะสอดคล้องกับการนำเครื่องมือ Remote Monitoring and Management (RMM) ไปใช้ในทางมิชอบ โดยมี MeshAgent เป็นองค์ประกอบสำคัญในการสร้างช่องทางควบคุมระบบจากระยะไกล หลังจากผู้โจมตีสามารถเข้าถึงหรือรันคำสั่งบนระบบเป้าหมายได้แล้ว

MeshAgent เป็น Agent ของ MeshCentral ซึ่งใช้สำหรับบริหารจัดการเครื่องปลายทางจากระยะไกล โดย Agent จะเชื่อมต่อกลับไปยัง MeshCentral Server เพื่อให้ผู้ควบคุมสามารถจัดการเครื่อง ตรวจสอบสถานะระบบ ถ่ายโอนไฟล์ เปิด remote terminal หรือสั่งรันคำสั่งบนเครื่องปลายทางได้ ทั้งนี้ MeshAgent ไม่ใช่มัลแวร์โดยตัวเอง แต่เป็นเครื่องมือประเภท Dual-use Tool ที่สามารถถูกนำไปใช้ในทางมิชอบได้ หากถูกติดตั้งหรือกำหนดค่าให้เชื่อมต่อไปยัง Server ที่ผู้โจมตีควบคุม

1. กลไกการทำงานของ MeshAgent และไฟล์ Configuration



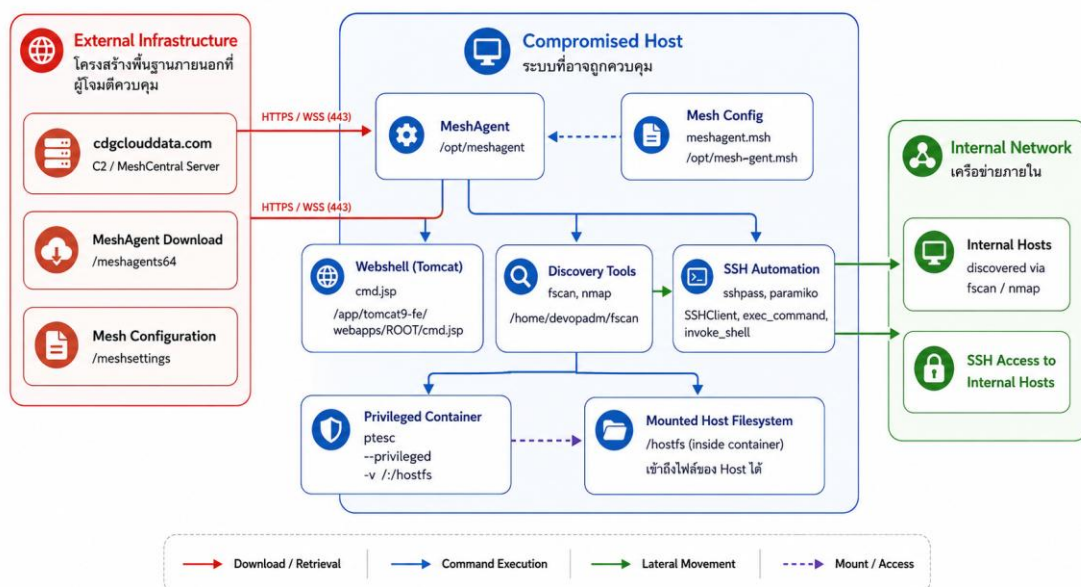
MeshAgent อาศัยไฟล์ Configuration นามสกุล .msh เพื่อกำหนดค่าที่จำเป็นสำหรับการเชื่อมต่อกลับไปยัง MeshCentral Server เช่น ชื่อ Mesh, Mesh ID, Server ID และที่อยู่ของ Server ที่ Agent ต้องเชื่อมต่อไป เมื่อ Agent ถูกติดตั้งและเริ่มทำงาน จะใช้ค่าจากไฟล์ดังกล่าวเพื่อสร้างการเชื่อมต่อกลับไปยัง Server ปลายทาง



ในเชิงภัยคุกคาม หากผู้โจมตีสามารถวาง MeshAgent และไฟล์ .msh บนระบบเป้าหมายได้ ผู้โจมตีอาจทำให้เครื่องดังกล่าวเข้าร่วมกับ MeshCentral Server ที่ตนควบคุมอยู่ ส่งผลให้สามารถควบคุมเครื่องจากระยะไกลได้โดยใช้เครื่องมือที่มีลักษณะเหมือนซอฟต์แวร์ดูแลระบบตามปกติ

ในกรณีนี้พบร่องรอยที่เกี่ยวข้องกับการดาวน์โหลด MeshAgent และไฟล์ Configuration จากโครงสร้างพื้นฐานภายนอก รวมถึงพบไฟล์ที่เกี่ยวข้องกับ MeshAgent บนระบบ เช่น /opt/meshagent และ /opt/meshagent.msh ซึ่งเป็นหลักฐานสำคัญที่ควรตรวจสอบร่วมกับ network connection, process execution และ service persistence

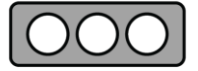
2. RMM ในฐานะช่องทางควบคุมระบบ



เครื่องมือ RMM มีความสามารถในการเชื่อมต่อกลับไปยัง Server ควบคุมผ่านเครือข่าย และสามารถใช้สำหรับ remote interaction กับเครื่องปลายทางได้ เช่น การเปิด remote shell, การถ่ายโอนไฟล์, การดูข้อมูลเครื่อง, การควบคุมหน้าจอ หรือการสั่งรันคำสั่ง

เมื่อถูกนำไปใช้ในทางมิชอบ RMM จึงสามารถทำหน้าที่คล้ายช่องทาง Command and Control ได้ โดยผู้โจมตีไม่จำเป็นต้องใช้มัลแวร์ที่พัฒนาขึ้นเอง แต่ใช้เครื่องมือที่ถูกต้องตามกฎหมายเพื่อหลบเลี่ยงการตรวจจับ และทำให้กิจกรรมบางส่วนดูคล้ายกับการดูแลระบบปกติ

ในกรณีนี้ การพบ C2 Domain และ URL ที่เกี่ยวข้องกับการดาวน์โหลด MeshAgent และ Mesh settings เป็นร่องรอยสำคัญที่บ่งชี้ว่า Agent อาจถูกกำหนดค่าให้เชื่อมต่อไปยังโครงสร้างพื้นฐานที่ไม่ได้เป็นขององค์กร



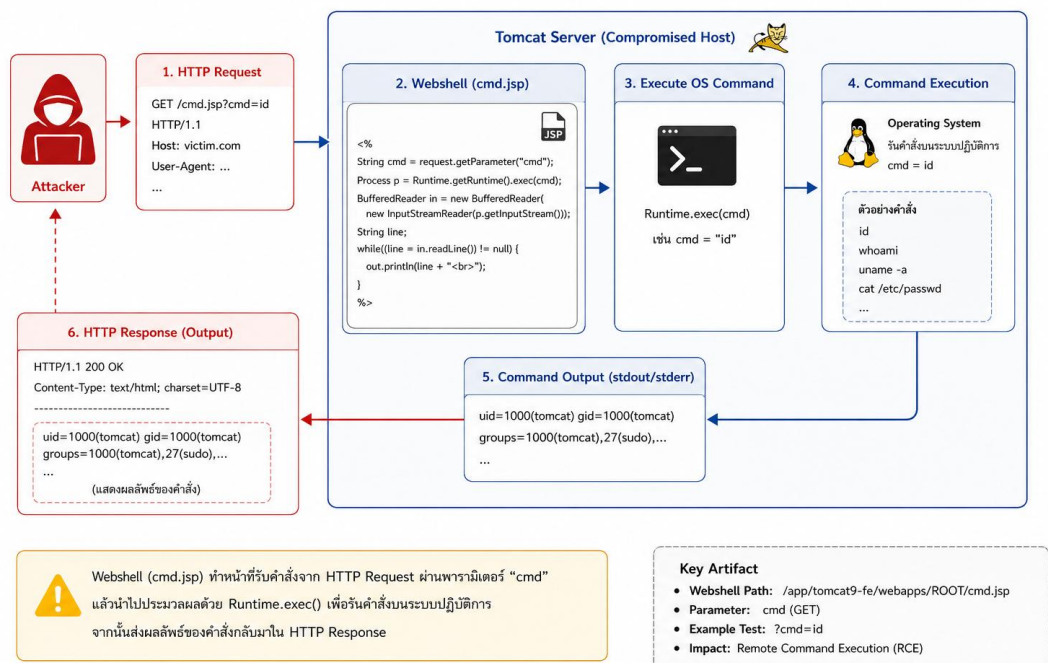
3. การพรางตัวด้วยชื่อไฟล์หรือ Service Name

หนึ่งในเทคนิคที่พบได้บ่อยในการใช้ RMM ในทางมิชอบ คือการเปลี่ยนชื่อไฟล์ ชื่อ service หรือ path ให้ดูเหมือนส่วนประกอบของระบบปฏิบัติการหรือซอฟต์แวร์ปกติ เพื่อลดโอกาสถูกสังเกตเห็นจากผู้ดูแลระบบ

ในข้อมูลที่ตรวจพบ มีไฟล์ที่มี hash เดียวกับ MeshAgent แต่ถูกวางไว้ใน path /usr/lib/udev/syssvc/syssvc ซึ่งมีลักษณะคล้าย service ของระบบ Linux การวางไฟล์ในตำแหน่งดังกล่าวควรถูกพิจารณาเป็นพฤติกรรมต้องสงสัย เนื่องจากอาจเป็นความพยายามในการ masquerading หรือพรางตัวให้ดูเหมือน service ปกติของระบบ

แนวทางการตรวจสอบควรพิจารณามากกว่าชื่อไฟล์ เช่น hash, parent process, command line, user ที่ติดตั้ง, network destination, service definition, timestamp และความสัมพันธ์กับไฟล์ .msh

4. Webshell บน Tomcat เพื่อสนับสนุน Command Execution



นอกจาก MeshAgent แล้ว ยังพบไฟล์ Webshell บนระบบ Tomcat ใน path /app/tomcat9-fe/webapps/ROOT/cmd.jsp โดยมีบริบทว่ามีการคัดลอกจาก source path ไปยัง Web Root และทดสอบคำสั่ง cmd=id พฤติกรรมนี้สะท้อนว่าผู้โจมตีอาจมีช่องทางสำหรับส่งรันทคำสั่งผ่าน HTTP Request



Webshell สามารถถูกใช้เป็นช่องทาง initial command execution หรือใช้เป็น backup access ควบคู่กับ RMM ได้ เช่น ใช้ดาวน์โหลดไฟล์เพิ่มเติม สั่งรัน MeshAgent ตรวจสอบสิทธิ์ของ process สำรจาระบบ หรือแก้ไขไฟล์บน Web Server

การพบ Webshell ร่วมกับ RMM ทำให้ความเสี่ยงสูงขึ้น เนื่องจากผู้โจมตีอาจมีมากกว่าหนึ่งช่องทางในการกลับเข้าระบบ ได้แก่ Webshell ผ่าน Web Application และ MeshAgent ผ่าน RMM Infrastructure

5. เครื่องมือสำรวจเครือข่ายและ SSH Automation

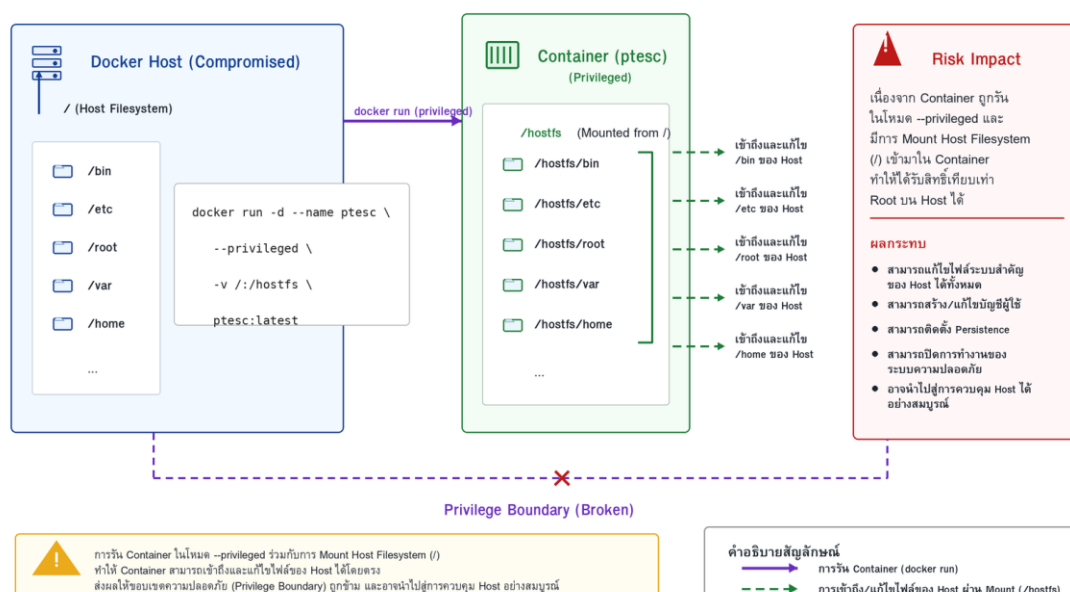
พบเครื่องมือ fscan และ nmap ซึ่งมักถูกใช้ในการสำรวจระบบและบริการภายในเครือข่าย เช่น การตรวจสอบ IP ที่มีชีวิตอยู่ พอร์ตที่เปิดอยู่ และบริการที่สามารถเข้าถึงได้ โดยในกรณีนี้ fscan ถูกพบใน path /home/devopadm/fscan และมี verdict เป็น MALWARE จาก Cortex XDR ขณะที่ nmap ถูกระบุว่าใช้ในบริบทของ reconnaissance

นอกจากนี้ ยังพบร่องรอยที่เกี่ยวข้องกับ SSH Automation เช่น sshpass, paramiko, SSHClient(), AutoAddPolicy(), connect(), exec_command() และ invoke_shell() ซึ่งสะท้อนถึงการใช script หรือเครื่องมือเพื่อเชื่อมต่อ SSH ไปยังเป้าหมายและรันคำสั่งระยะไกล

พฤติกรรมดังกล่าวอาจเกี่ยวข้องกับการทดลอง credential, การรันคำสั่งบนเครื่องอื่น หรือการเคลื่อนย้ายภายในเครือข่าย โดยควรตรวจสอบ SSH authentication log, source IP, username, failed/success login, command history และความสัมพันธ์กับช่วงเวลาที่มีการรันเครื่องมือสำรวจเครือข่าย



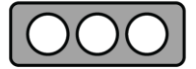
6. ความเสี่ยงจาก Privileged Container



พบข้อมูลที่เกี่ยวข้องกับ Docker Container ชื่อ ptesc ซึ่งมีลักษณะเป็น privileged container และมีการ mount host filesystem / เข้าไปที่ /hostfs ภายใน container พฤติกรรมนี้มีความเสี่ยงสูง เนื่องจาก container ที่ได้รับสิทธิ์มากเกินไปอาจถูกใช้เพื่อเข้าถึงไฟล์ของ host หรือใช้เป็นช่องทางขยายสิทธิ์จาก container ไปยัง host environment

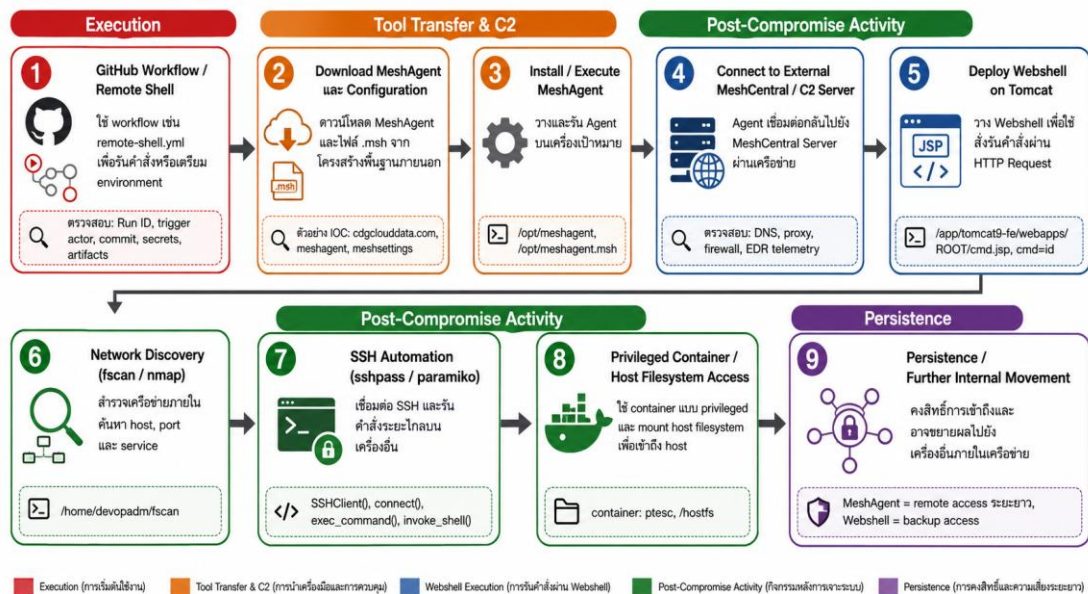
การ mount host root filesystem เข้าไปใน container ทำให้ process ภายใน container อาจสามารถอ่านหรือแก้ไขไฟล์บน host ได้ ขึ้นอยู่กับสิทธิ์และ configuration ที่กำหนดไว้ จึงควรตรวจสอบ Docker run command, container inspect, mounted volume, privileged flag, process ภายใน container และไฟล์ที่ถูกเข้าถึงผ่าน /hostfs

โดยสรุป ภาพรวมทางเทคนิคของกรณีนี้สะท้อนถึงการใช้เครื่องมือ RMM ที่ถูกต้องตามกฎหมายร่วมกับ Webshell เครื่องมือสำรวจเครือข่าย SSH Automation และ Container ที่มีสิทธิ์สูง ซึ่งอาจช่วยให้ผู้โจมตีสามารถควบคุมระบบ คงสิทธิ์การเข้าถึง สำรวจเครือข่าย และขยายผลการโจมตีภายในระบบได้



Attack Flow

จากข้อมูล IOC และร่องรอยทางเทคนิคที่ตรวจพบ สามารถประเมินลำดับการโจมตีที่เป็นไปได้ในกรณีนี้ว่า ผู้โจมตีอาจใช้ช่องทางการรันคำสั่งผ่าน GitHub Workflow หรือ Remote Shell เป็นจุดเริ่มต้น ก่อนดาวน์โหลดและติดตั้ง MeshAgent เพื่อใช้เป็นช่องทางควบคุมระบบระยะไกล จากนั้นจึงใช้ Webshell เครื่องมือสำรวจเครือข่าย SSH Automation และ Container ที่มีสิทธิ์สูง เพื่อสนับสนุนการควบคุมระบบและขยายผลการโจมตีภายในเครือข่าย



1. GitHub Workflow / Remote Shell

ข้อมูลที่ตรวจพบระบุถึง GitHub Repository และ Workflow ชื่อ remote-shell.yml ซึ่งถูกระบุเป็นเส้นทางหลักของการรันคำสั่ง โดยลักษณะดังกล่าวอาจสะท้อนการใช้ CI/CD หรือ Workflow Automation เป็นช่องทาง execution เพื่อรันคำสั่ง ดาวน์โหลดไฟล์ หรือเตรียม environment สำหรับกิจกรรมในขั้นตอนถัดไป

ในขั้นตอนนี้ควรตรวจสอบประวัติการรัน Workflow, Run ID ที่เกี่ยวข้อง, ผู้ที่ trigger workflow, commit ที่เปลี่ยนแปลง, secret หรือ token ที่ถูกใช้งาน และ artifact ที่ถูกสร้างขึ้นระหว่างการทำงานของ pipeline

2. Download MeshAgent และ Configuration

หลังจากมีช่องทางรันคำสั่ง ผู้โจมตีอาจดาวน์โหลด MeshAgent และไฟล์ Configuration จากโครงสร้างพื้นฐานภายนอก โดยในข้อมูล IOC พบ domain และ URL ที่เกี่ยวข้องกับ



การดาวน์โหลด MeshAgent และ Mesh settings ซึ่งสอดคล้องกับการเตรียม Agent เพื่อเชื่อมต่อกลับไปยัง Server ควบคุม

ไฟล์ Configuration นามสกุล .msh มีความสำคัญ เนื่องจากใช้กำหนดค่าที่จำเป็นสำหรับการเชื่อมต่อ เช่น Mesh ID, Server ID และที่อยู่ของ MeshCentral Server หรือ C2 ที่ Agent ต้องเชื่อมต่อ

3. Install / Execute MeshAgent

เมื่อ MeshAgent และไฟล์ Configuration ถูกวางบนระบบเป้าหมาย ผู้โจมตีอาจสั่งรัน Agent เพื่อให้เครื่องเป้าหมายเชื่อมต่อกลับไปยัง MeshCentral Server ที่ควบคุมอยู่ จากข้อมูลที่มีร่องรอยของไฟล์ /opt/meshagent และ /opt/meshagent.msh ซึ่งควรถูกตรวจสอบร่วมกับ process execution, command line, service persistence และ network connection

ในเชิงภัยคุกคาม การรัน MeshAgent ทำให้ผู้โจมตีสามารถใช้เครื่องมือ RMM ที่ถูกต้องตามกฎหมายเป็นช่องทาง remote administration โดยไม่จำเป็นต้องใช้มัลแวร์เฉพาะทาง

4. Connect to External MeshCentral / C2 Server

หลังจาก Agent ทำงาน MeshAgent จะใช้ค่าจากไฟล์ .msh เพื่อเชื่อมต่อกลับไปยัง MeshCentral Server ผ่านเครือข่าย โดย RMM ลักษณะนี้สามารถใช้เป็นช่องทางควบคุมระบบ ถ้าย้อนไฟล์ เปิด remote terminal หรือสั่งรันคำสั่งจากระยะไกลได้

ในกรณีนี้ การพบ domain ภายนอกที่เกี่ยวข้องกับ MeshAgent เช่น cdgclouddata.com และ URL สำหรับดาวน์โหลด agent/config เป็นร่องรอยสำคัญที่ควรนำไปตรวจสอบใน DNS log, proxy log, firewall log และ EDR network telemetry

5. Deploy Webshell on Tomcat

นอกจากช่องทาง RMM แล้ว ยังพบ Webshell บนระบบ Tomcat ใน path /app/tomcat9-fe/webapps/ROOT/cmd.jsp โดยมีบริบทที่ถูกคัดลอกจาก source path ไปยัง Web Root และมีการทดสอบคำสั่ง cmd=id Webshell ดังกล่าวอาจถูกใช้เป็นช่องทางสำรองสำหรับ command execution ผ่าน HTTP Request

การมีทั้ง MeshAgent และ Webshell ในระบบเดียวกันเพิ่มความเสี่ยงอย่างมีนัยสำคัญ เนื่องจากผู้โจมตีอาจมีหลายช่องทางการกลับเข้าระบบ เช่น ใช้ Webshell สำหรับรันคำสั่งเฉพาะหน้า และใช้ MeshAgent สำหรับควบคุมระบบระยะยาว



6. Network Discovery ด้วย fscan และ nmap

หลังจากมี foothold บนระบบ ผู้โจมตีอาจเริ่มสำรวจเครือข่ายภายในเพื่อค้นหาเครื่องปลายทาง พอร์ตที่เปิดอยู่ และบริการที่สามารถเข้าถึงได้ โดยในข้อมูล IOC พบ fscan ที่ path /home/devopadm/fscan และพบ nmap ในบริบทของ reconnaissance

พฤติกรรมนี้สอดคล้องกับ post-compromise activity ซึ่งมักเกิดหลังจากผู้โจมตีเข้าถึงระบบได้แล้ว เพื่อระบุเป้าหมายสำหรับการเคลื่อนย้ายภายในเครือข่ายหรือการเข้าถึงระบบสำคัญเพิ่มเติม

7. SSH Automation ด้วย sshpass และ paramiko

ข้อมูลที่ตรวจพบมีร่องรอยของเครื่องมือและโค้ดที่เกี่ยวข้องกับ SSH Automation เช่น sshpass, paramiko, SSHClient(), AutoAddPolicy(), connect(), exec_command() และ invoke_shell() ซึ่งอาจถูกใช้เพื่อเชื่อมต่อไปยังเครื่องอื่นผ่าน SSH และรันคำสั่งระยะไกล

ในขั้นตอนนี้ควรตรวจสอบ SSH authentication log, source IP, username, จำนวน failed/success login, command history และความสัมพันธ์กับช่วงเวลาที่มีการรัน fscan หรือ nmap เพื่อประเมินว่ามี lateral movement สำเร็จหรือไม่

8. Privileged Container / Host Filesystem Access

พบ Docker Container ชื่อ ptesc ที่มีลักษณะเป็น privileged container และมีการ mount host filesystem / เข้าไปที่ /hostfs ภายใน container พฤติกรรมนี้มีความเสี่ยงสูงเนื่องจากอาจทำให้ process ภายใน container สามารถเข้าถึงไฟล์ของ host หรือใช้เป็นช่องทางขยายสิทธิ์จาก container ไปยัง host environment ได้

ควรตรวจสอบ Docker run command, container inspect, mounted volume, privileged flag, process ภายใน container และไฟล์ที่ถูกอ่านหรือแก้ไขผ่าน /hostfs

9. Persistence / Further Internal Movement

จากการพบ MeshAgent, ไฟล์ Configuration, Webshell, เครื่องมือสำรวจเครือข่าย และ SSH Automation ทำให้ประเมินได้ว่าผู้โจมตีอาจมีความพยายามในการคงสิทธิ์การเข้าถึงระบบ และอาจพยายามขยายผลไปยังเครื่องอื่นภายในเครือข่าย

MeshAgent สามารถทำหน้าที่เป็นช่องทาง remote access ระยะยาว ขณะที่ Webshell สามารถเป็น backup access และเครื่องมืออย่าง fscan, nmap, sshpass และ paramiko สามารถสนับสนุนการสำรวจและเคลื่อนย้ายภายในระบบได้



Tactics, Techniques, and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Execution	T1059.004	Command and Scripting Interpreter: Unix Shell
	T1059.006	Command and Scripting Interpreter: Python
Persistence	T1505.003	Server Software Component: Web Shell
Command and Control	T1219	Remote Access Tools
	T1105	Ingress Tool Transfer
Defense Evasion	T1036.005	Masquerading: Match Legitimate Resource Name or Location
Discovery	T1046	Network Service Discovery
Lateral Movement	T1021.004	Remote Services: SSH
Privilege Escalation	T1611	Escape to Host
Persistence / Defense Evasion	T1078	Valid Accounts



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

Domain / URL

C2 Domain: cdgclouddata.com

C2 URL: <https://www.cdgclouddata.com/meshagents?id=6>

C2 URL:

[https://www.cdgclouddata.com/meshsettings?id=GZ4\\$ipRAMck\\$bg\\$OaeZZj1fxlwzAqo6gEVzvgZ1yElgoKFmo4YKLGXnQS1V61f4](https://www.cdgclouddata.com/meshsettings?id=GZ4$ipRAMck$bg$OaeZZj1fxlwzAqo6gEVzvgZ1yElgoKFmo4YKLGXnQS1V61f4)

Hash

SHA-256: e82ecbe3823046a27d8c39cc0a4acb498f415549946c9ff0e241838b34ed5a21

MD5: b8053bcd04ce9d7d19c7f36830a9f26b

SHA-256: 460acbb38b0bdb3d227de65010b1a323f448ec196860ce4979c0b8314763eb56

SHA-256: dcf99ae0aa31fee1c5d3d6d53c99e8d11b0cb82cdb3ab81248ace279fe639708

SHA-256: c5c25526a3f9bc2408925f0281006031b781bd7a08007da7491570b80042f27b

SHA-256: f3e8777133f371be031b9d151729518ce1c5c7340b3f9937660697285f57a3f7



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

จากลักษณะภัยคุกคามที่พบ หน่วยงานควรให้ความสำคัญกับการตรวจสอบการใช้งานเครื่องมือ Remote Monitoring and Management (RMM), การเชื่อมต่อออกไปยังโครงสร้างพื้นฐานภายนอก, การพบ Webshell บนระบบ Web Application, การใช้เครื่องมือสำรวจเครือข่าย และพฤติกรรมที่เกี่ยวข้องกับ SSH Automation หรือ Container ที่มีสิทธิ์สูง

1. แนวทางการเฝ้าระวังและตรวจจับ

1.1 ตรวจสอบการใช้งาน MeshAgent หรือเครื่องมือ RMM ที่ไม่ได้รับอนุญาต โดยพิจารณาจาก process, service, binary, path และปลายทางที่เครื่องมือดังกล่าวเชื่อมต่อไป

1.2 ตรวจสอบไฟล์ Configuration ของ MeshAgent เช่น ไฟล์นามสกุล .msh โดยเฉพาะ path /opt/meshagent.msh และตรวจสอบค่า Server หรือ MeshCentral Server ที่ระบุอยู่ในไฟล์

1.3 ตรวจสอบ DNS log, Proxy log และ Firewall log เพื่อค้นหาการเชื่อมต่อไปยัง cdgclouddata.com หรือ domain ภายนอกที่ไม่อยู่ในรายการอนุญาตขององค์กร

1.4 ตรวจสอบ Web Server และ Web Root เพื่อค้นหาไฟล์ Webshell หรือไฟล์ script ที่ถูกเพิ่มหรือแก้ไขผิดปกติ โดยเฉพาะ path /app/tomcat9-fe/webapps/ROOT/cmd.jsp

1.5 ตรวจสอบการรันเครื่องมือสำรวจเครือข่าย เช่น fscan และ nmap โดยพิจารณาพร้อมกับช่วงเวลา, account ที่ใช้งาน, command line และปลายทางที่ถูก scan

1.6 ตรวจสอบพฤติกรรมที่เกี่ยวข้องกับ SSH Automation เช่น การใช้งาน sshpass, paramiko, SSHClient(), AutoAddPolicy(), connect(), exec_command() และ invoke_shell()

1.7 ตรวจสอบ SSH authentication log เพื่อค้นหารูปแบบการ login ที่ผิดปกติ เช่น การ login ล้มเหลวจำนวนมาก, การ login สำเร็จจากแหล่งที่ไม่คุ้นเคย หรือการใช้งานบัญชีเดียวกันกับหลายเครื่องภายในช่วงเวลาสั้น

1.8 ตรวจสอบ Docker Container หรือ Container Runtime ว่ามี container ที่รันด้วยสิทธิ์ privileged หรือมีการ mount host filesystem เช่น /hostfs หรือไม่

1.9 ตรวจสอบ GitHub Actions หรือ CI/CD log ที่เกี่ยวข้องกับ workflow ต้องสงสัย เช่น remote-shell.yml, Run ID, ผู้ที่ trigger workflow, commit ที่เกี่ยวข้อง, secret usage และ artifact ที่ถูกสร้างขึ้นระหว่าง pipeline



2. แนวทางการป้องกัน

2.1 สำรวจและจัดทำรายการเครื่องมือ RMM หรือ remote access ที่ใช้งานในองค์กร เช่น MeshAgent, AnyDesk, TeamViewer, ScreenConnect, RustDesk และเครื่องมืออื่นที่มีลักษณะใกล้เคียงกัน

2.2 จัดทำรายการเครื่องมือ RMM ที่ได้รับอนุญาต โดยระบุชื่อเครื่องมือ ผู้รับผิดชอบ เครื่องที่อนุญาตให้ติดตั้ง และ server หรือ domain ที่เครื่องมือดังกล่าวสามารถเชื่อมต่อได้

2.3 ใช้ application control หรือ allowlisting เพื่ออนุญาตให้รันเฉพาะโปรแกรมที่องค์กรกำหนดไว้ และลดโอกาสการรัน RMM, scanner หรือ remote access tool ที่ไม่ได้รับอนุญาต

2.4 จำกัดสิทธิ์ผู้ใช้งานทั่วไปไม่ให้อาจติดตั้ง agent, สร้าง service, แก้ไข configuration สำคัญ หรือเพิ่ม startup mechanism ได้เองโดยไม่จำเป็น

2.5 บังคับใช้ Multi-Factor Authentication (MFA) กับระบบ remote access, VPN, RMM console, GitHub, CI/CD platform และบัญชีผู้ดูแลระบบ

2.6 จำกัดการเชื่อมต่อออกไปยัง domain หรือ IP ภายนอกที่ไม่จำเป็น ผ่าน firewall, proxy, DNS filtering หรือ EDR policy โดยเฉพาะปลายทางที่เกี่ยวข้องกับ RMM ที่ไม่ได้รับอนุญาต

2.7 เสริมความปลอดภัยของ GitHub Actions และ CI/CD Pipeline โดยตรวจสอบ workflow permission, secret, token, branch protection และการอนุมัติ workflow ที่มีความเสี่ยงสูง

2.8 เสริมความปลอดภัยของ Web Server โดยจำกัดสิทธิ์การเขียนไฟล์ใน Web Root, ตรวจสอบ file upload, ใช้ File Integrity Monitoring และตรวจสอบไฟล์ script ที่ถูกเพิ่มใหม่อย่างสม่ำเสมอ

2.9 เสริมความปลอดภัยของ Container โดยหลีกเลี่ยงการใช้ privileged container, จำกัด volume mount, ใช้หลัก least privilege และตรวจสอบ container runtime configuration อย่างสม่ำเสมอ



3. แนวทางการรับมือเมื่อพบ IOC หรือพฤติกรรมต้องสงสัย

3.1 แยกเครื่อง endpoint, server หรือ container ที่พบ IOC ออกจากเครือข่ายชั่วคราว เพื่อจำกัดการเชื่อมต่อไปยัง C2 หรือการขยายผลไปยังระบบอื่น

3.2 เก็บหลักฐานที่เกี่ยวข้อง เช่น process list, network connection, file hash, timestamp, service list, web server log, GitHub Actions log, SSH log และ container inspect output

3.3 ตรวจสอบว่า MeshAgent หรือ RMM ที่พบถูกติดตั้งโดยผู้ดูแลระบบจริงหรือไม่ และตรวจสอบว่าเชื่อมต่อไปยัง server ที่องค์กรอนุญาตหรือไม่

3.4 วิเคราะห์ไฟล์ .msh เพื่อระบุค่า Mesh ID, Server ID, MeshServer และปลายทางที่ Agent พยายามเชื่อมต่อ

3.5 ตรวจสอบและเก็บหลักฐานไฟล์ Webshell รวมถึงตรวจสอบ Web Server access log เพื่อดูว่ามีการเรียกใช้งานคำสั่งใดผ่าน Webshell หรือไม่

3.6 ตรวจสอบการรัน fscan, nmap และ connection ไปยัง host ภายในเครือข่าย เพื่อประเมินว่ามีการสำรวจเครือข่ายหรือ lateral movement หรือไม่

3.7 ตรวจสอบ SSH authentication log, username, source IP, failed/success login และ command history เพื่อประเมินว่ามีการเชื่อมต่อไปยังเครื่องอื่นสำเร็จหรือไม่

3.8 ตรวจสอบ container ที่ใช้ privileged mode หรือ mount /hostfs และตรวจสอบว่าไฟล์บน host ถูกอ่าน แก้ไข หรือคัดลอกออกไปหรือไม่

3.9 เปลี่ยนรหัสผ่านหรือ revoke credential/token ที่เกี่ยวข้อง โดยเฉพาะบัญชีผู้ดูแลระบบ, SSH key, GitHub token, CI/CD secret และ credential ที่อาจถูกใช้ใน automation

3.10 ดำเนินการ threat hunting เพิ่มเติมในเครื่องอื่นภายในเครือข่าย เพื่อค้นหา MeshAgent, ไฟล์ .msh, Webshell, fscan, nmap, sshpass, paramiko หรือพฤติกรรมที่คล้ายกัน

4. แนวทางการตรวจสอบเชิงลึกเพิ่มเติม

4.1 ตรวจสอบ DNS และ Proxy log ย้อนหลัง เพื่อค้นหาการเชื่อมต่อไปยัง cdgclouddata.com

4.2 ตรวจสอบ endpoint telemetry เพื่อค้นหาการรัน /opt/meshagent, /usr/lib/udev/syssvc/syssvc, fscan, nmap และ sshpass



4.3 ตรวจสอบ Web Server access log เพื่อค้นหาการเรียกใช้งาน /cmd.jsp หรือ parameter ที่เกี่ยวข้องกับ cmd

4.4 ตรวจสอบ GitHub Actions log เพื่อระบุคำสั่งที่ถูก execute ผ่าน remote-shell.yml

4.5 ตรวจสอบ SSH log เพื่อประเมินว่ามี lateral movement สำเร็จหรือไม่

4.6 ตรวจสอบ container runtime log เพื่อยืนยันการรัน container ptsc และการ mount /hostfs

4.7 ตรวจสอบ persistence mechanism เช่น systemd service, cron job, startup script หรือไฟล์ที่ถูกเพิ่มใน path ของระบบ

5. ข้อเสนอแนะเชิงนโยบาย

5.1 กำหนดนโยบายควบคุมการใช้งาน RMM และ remote access อย่างเป็นระบบ โดยระบุเครื่องมือที่อนุญาตให้ใช้งาน เจ้าของระบบ ผู้รับผิดชอบ และขอบเขตการใช้งานที่ชัดเจน

5.2 ทบทวนรายการ RMM ที่ได้รับอนุญาตเป็นระยะ และตรวจสอบว่าเครื่องมือที่ใช้งานอยู่ยังมีความจำเป็นและเชื่อมต่อไปยัง server ที่องค์กรควบคุมจริง

5.3 กำหนดกระบวนการแจ้งเตือนและสืบสวนเมื่อพบ RMM ที่ไม่อยู่ใน allowlist หรือพบการเชื่อมต่อไปยัง server ภายนอกที่ไม่เกี่ยวข้องกับองค์กร

5.4 ใช้แนวทางป้องกันแบบผสมผสานระหว่าง RMM governance, application control, network monitoring, endpoint detection, CI/CD security, web server hardening และ container security

5.5 ไม่ควรพึ่งพาการ block hash หรือ domain เพียงอย่างเดียว เนื่องจากผู้โจมตีสามารถเปลี่ยนชื่อไฟล์, path, hash, service name หรือโครงสร้างพื้นฐานได้ ควรใช้ behavior-based detection และ threat hunting ร่วมด้วย



อ้างอิง (References)

[1] Cybersecurity and Infrastructure Security Agency (CISA), National Security Agency (NSA), and Multi-State Information Sharing and Analysis Center (MS-ISAC). Protecting Against Malicious Use of Remote Monitoring and Management Software, Cybersecurity Advisory AA23-025A, 2023.

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-025a>

[2] Intel 471. Understanding and threat hunting for RMM software misuse, 2025.

<https://www.intel471.com/blog/understanding-and-threat-hunting-for-rmm-software-misuse>

[3] Ylianst. MeshAgent: MeshAgent used along with MeshCentral to remotely manage computers, GitHub Repository.

<https://github.com/Ylianst/MeshAgent>

[4] National Security Agency (NSA). NSA, CISA, and MS-ISAC Release Guidance for Securing Remote Monitoring and Management Software, 2023.

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/3277084/nsa-cisa-and-ms-isac-release-guidance-for-securing-remote-monitoring-and-manage/>





แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th